

Capsule Numérique Posthume – Plan sécurité, pentest et conformité

1. Objectifs du plan de sécurité

- Garantir la confidentialité absolue des données des utilisateurs via chiffrement de bout en bout (E2E).
- Assurer l'intégrité et la traçabilité des opérations critiques (ajout contenu, désignation héritiers, déclenchement).
- Prévenir les risques d'accès non autorisé ou de compromission du service.
- Maintenir la conformité légale (CNIL, RGPD, Loi Informatique & Libertés art.85).
- Renforcer la confiance des utilisateurs et partenaires (assureurs, notaires).

2. Check-list OWASP ASVS (synthèse adaptée)

Domaine	Contrôles essentiels
Authentification	OIDC + MFA (TOTP/SMS), gestion robuste des sessions, tokens courts.
Gestion accès	RBAC strict, séparation totale des données par utilisateur, pas de super-admin global.
Protection données	Chiffrement E2E (Argon2id + XChaCha20), secret sharing Shamir pour héritiers.
Sécurité transport	TLS 1.3, HSTS, CSP stricte, cookies SameSite/HttpOnly.
Journalisation	Logs append-only, horodatage TSA, surveillance anomalies.
Resilience	Sauvegardes chiffrées, réplication multi-régions, tests restauration mensuels.

3. Plan de pentest

- Tests boîte noire (simulateur d'attaquant externe) : injection, XSS, CSRF, brute force, escalade privilèges.
- Tests boîte grise (accès utilisateur légitime) : contournement MFA, export massif de données, altération héritiers.
- Tests boîte blanche (audit code + infra) : analyse crypto, validation Argon2id, vérif implémentation secret sharing.
- Cas d'abus critiques : - Faux signal décès déclenchant un accès prématuré. - Héritier malveillant tentant un déblocage anticipé. - Compromission du stockage cloud (S3).

4. Conformité RGPD & CNIL

- Responsable de traitement identifié (société éditrice de la Capsule).
- Données sensibles : documents personnels, messages posthumes → mesures renforcées.
- RGPD Considérant 27 : non applicable aux personnes décédées, mais Loi FR art.85 LIL encadre l'accès post-mortem.
- Registre de traitements obligatoire (description, finalité, durée, base légale).
- Droits : directives posthumes (CNIL), droit d'effacement, export.
- DPO recommandé (interne ou externe).

5. DPIA (Analyse d'impact vie privée)

- Finalité : conservation et transmission sécurisée de données post-mortem.
- Risques : accès non autorisé, perte de données, déclenchement anticipé.
- Mesures : chiffrement E2E, secret sharing, vérification multi-signal décès, sauvegardes immuables.
- Impact résiduel : moyen-faible si mesures respectées.

6. Audit et suivi

- Audit sécurité initial avant lancement (pentest complet).
- Audit annuel (code, infra, conformité).
- Bug bounty privé (via YesWeHack/HackerOne restreint).
- Politique de sécurité publique (transparence).
- Formation sécurité continue de l'équipe technique.

Conclusion

La Capsule Numérique doit être conçue « security by design » et « privacy by default ». La combinaison de contrôles OWASP, de pentests réguliers et d'une conformité RGPD/CNIL robuste est un levier majeur de différenciation face aux acteurs internationaux, et un facteur essentiel de confiance pour les utilisateurs et partenaires.